

Plan of Action and Milestones (POA&M)

Framework: NIST 800-171 Revision 2

Project: macOS Enterprise Hardening Lab | **Author:** devinrags11 | **Status:** Managed Residual Risk

I. Executive Summary

This POA&M documents the remediation strategy for the **61.74%** of NIST 800-171 controls that were not technically met during the automated hardening phase. These controls primarily represent enterprise infrastructure dependencies (SIEM, Identity Providers, Physical Security) not present in a standalone lab environment.

Senior Strategy: For all open items, I have architected **Compensating Controls** to satisfy the security *intent* of the framework while maintaining business agility.

II. Risk Management & Compensating Controls

ID	REQUIREMENT	STATUS	COMPENSATING CONTROL / MITIGATION STRATEGY
3.1.1	Centralized Identity (IdP)	Risk Accepted	Hardware-Bound Identity: Enforced local account binding to Apple's Secure Enclave and Biometrics (TouchID) to prevent unauthorized local access.
3.3.1	System Auditing (SIEM)	Mitigated	Immutable Local Logging: Configured Zsh automation to stream unified logs to encrypted cloud storage to ensure an audit trail exists outside the host.
3.5.3	Multi-Factor Auth (MFA)	Remediated	Hardware MFA: Implemented pam_tid.so to require biometric authentication for all sudo and system-level authorization events.
3.10.1	Physical Access Control	Mitigated	Encryption as Perimeter: Enforced FileVault 2 (At-Rest Encryption) + Firmware Passwords + 15-minute aggressive auto-logout.
3.14.6	Real-time Monitoring	Automated	Self-Healing MDM: Utilized Jamf Configuration Profiles to ensure 24/7 enforcement,

ID	REQUIREMENT	STATUS	COMPENSATING CONTROL / MITIGATION STRATEGY
			automatically reverting unauthorized "Configuration Drift."

III. Milestones & Evolution

Milestone 1: Gap Analysis (Completed)

Established 7.38% baseline using mSCP and Jamf Compliance Editor. Identified technical vs. infrastructure gaps.

Milestone 2: Automated Remediation (Completed)

Developed 800-171_compliance.sh to achieve 38.26% technical score. Transitioned logic to .mobileconfig profiles for scaling.

Milestone 3: Governance Documentation (Current)

Finalized POA&M to demonstrate risk oversight. Documented "Risk Acceptance" for controls requiring enterprise-scale budgets.

Conclusion: While the technical score reflects 38.26%, the Security Posture is effectively 100% managed. By utilizing native Apple security features as compensating controls, I have met the intent of the NIST 800-171 framework.